

TURVAAUDIT & LIIKLUSANALÜÜS

Võrguliikluse Analüüsi Aruanne

Autonoomse vahelüli (MITM) süsteemi ehitamine ja IoT seadme käitumise monitooring

Dokumendi tüüp:	Tehniline teostus- ja analüüsiraport
Sihtmärkseade:	Nutikas robottolmuimeja (Ecovacs Deebot N20)
Testplatvorm:	Raspberry Pi 5 (Bookworm OS)
Püüdmistarkvara:	TShark (Wireshark CLI), NetworkManager
Kuupäev:	19. juuli 2026

1. Sissejuhatus ja projekti eesmärk

Käesoleva projekti eesmärk oli luua kontrollitud ja läbipaistev testkeskkond asjade interneti (IoT) seadmete võrgukäitumise uurimiseks ning tuvastada, kas sihtmärgiks valitud robot käitub võrgus anomaalselt või kahtlaselt. Praktiliseks sihtmärgiks valiti robottolmuimeja, mille andmevahetust välisserverite ja juhtseadmega (nutitelefoniga) sooviti reaalajas pealt kuulata ja analüüsida.

Eesmärgi saavutamiseks realiseeriti füüsilise vahelüli (Man-in-the-Middle ehk MITM alternatiivne versioon) arhitektuur. Erinevalt tarkvaralisest ARP-spoofing ründest, mis tugineb kohaliku võrgu marsruutimistabelite manipuleerimisele ja võib olla ebastabiilne, kasutati siin spetsiaalset riistvaralist lahendust. Raspberry Pi 5 seadistati autonoomseks pääsupunktiks ja ruuteriks, mis positsiooniti otse sihtmärgi ja lairiba-internetiühenduse vahele. Selline lähenemine tagab absoluutse stabiilsuse, kuna püüdurseade omab täielikku kontrolli füüsilise ja loogilise kanali üle ilma võrgutõrkeid tekitamata.

2. Süsteemi arhitektuur ja võrguliidesed

Raspberry Pi 5 konfigureeriti toimima inline-marsruuterina järgmise jaotuse alusel:

- WAN-liides (eth0):** Integreeritud füüsiline võrgukaardi port, mis on ühendatud põhivõrku või modemi külge. See saab IP-aadressi automaatselt DHCP kaudu ja tagab internetiühenduse.
- LAN/Pääsupunkt (wlan0):** Raspberry Pi integreeritud Wi-Fi moodul, mis on seadistatud autonoomseks pääsupunktiks (Hotspot) nimega HoneyMoon. Selle liidese staatiliseks IP-aadressiks määrati NetworkManager'i poolt vaikimisi 10.42.0.1.

Liides	Roll süsteemis	IP Konfiguratsioon
eth0	WAN (Võrgu sisend / Internet)	DHCP Kliendi režiim (automaatne sihtmärkvõrgust)

Liides	Roll süsteemis	IP Konfiguratsioon
wlan0	LAN / Pääsupunkt (Hotspot)	Staatiline (NetworkManager'i poolt määratud: 10.42.0.1)

3. Süsteemi seadistamine samm-sammult

Samm 1: Süsteemi värskendamine

Operatsioonisüsteemi paketibaasi ajakohastamiseks ja võrguteenuste stabiilsuse tagamiseks käivitati järgmine käsk:

```
sudo apt update && sudo apt upgrade -y
```

Samm 2: Wi-Fi Hotspoti loomine

Network Manageri CLI tööriista (nmcli) abil loodi spetsiaalse parooliga pääsupunkt nimega HoneyMoon:

```
sudo nmcli device wifi hotspot ifname wlan0 ssid HoneyMoon password
<minu_turvaline_parool>
```

Märkus halduse kohta: Pärast käsu täitmist lülitub Wi-Fi moodul AP-režiimi ning olemasolev juhtmevaba SSH-ühendus katkeb. Halduse jätkamiseks ühendati administraatori arvuti samasse HoneyMoon võrku ja logiti sisse uuel kolmanda astme võrguaadressilt 10.42.0.1.

Samm 3: Automaatse ühenduse lubamine

Selleks, et pääsupunkt käivituks automaatselt ka pärast seadme taaskäivitust, sisestati järgmine modifikatsioon:

```
sudo nmcli connection modify Hotspot connection.autoconnect yes
```

Samm 4: Väliste andmekandja ettevalmistamine

Kuna võrguliikluse maht võib olla märkimisväärne, ühendati Raspberry Pi külge väline USB-mälupulk (/dev/sda), mis vormindati ja haagiti puhtasse süsteemsesse kataloogi, vältides töölauakeskkonna piiranguid:

```
umount /media/user/* 2>/dev/null
mkdir -p /mnt/sda
mount /dev/sda /mnt/sda
```

4. Võrguliikluse püüdmine (Capture Workflow)

Liikluse autonoomseks salvestamiseks paigaldati Wiresharki käsurea-versioon tshark:

```
sudo apt install tshark -y
```

Püüdmisprotsess algatati paralleelselt mõlemal liidesel, kasutades andmete kadumise või faili korrumppeerumise vältimiseks nn Ring Buffer režiimi. Ühe faili limiidiks määrati 100 MB, mille täitumisel genereeritakse automaatselt uus järjekorranumbriga fail:

```
tshark -i eth0 -b filesize:100000 -w /mnt/sda/eth0_capture.pcapng &  
tshark -i wlan0 -b filesize:100000 -w /mnt/sda/wlan0_capture.pcapng &
```

Sümbol & käsu lõpus suunas protsessid taustale, võimaldades administraatoril konsooli tööd jätkata. Pärast seda ühendati robottolmuimeja Wi-Fi kaudu HoneyMoon võrku, samuti ühendati nutitelefon samasse pääsupunkti ning käivitati tolmuimeja juhtimisirakendus, et tekitada aktiivset andmevahetust.

Kui vajalikud toimingud oli sooritatud, peatati salvestamine turvaliselt käsuga:

```
killall tshark  
umount /mnt/sda
```

5. Võrguliikluse süvaanalüüs ja tulemused

Pärast 12-tunnist seiret salvestatud pcapng-failide lahkamist automatiseeritud analüüsiskriptide ja tshark päringute abil, joonistus välja sihtmärkseadme (Ecovacs Deebot N20) täielik käitumismuster. Tuvastatud paketid kajastavad täpset ja reeglipärast võrguliiklust.

A. Andmemahu ja protokollide jaotus

Andmete analüüs liidesel wlan0 tuvastas järgmised põhilised andmevood:

- Peamine välissõlm: 164.5.253.203 (kogu maht ~10.87 MB).
- Kõrgeima mahuga pordid ja protokollid:
 - UDP/36167 (8.10 MB)
 - UDP/51820 (1.05 MB - kokku 15 081 paketti)

Tehniline selgitus ("WireGuard anomaalia"): Kuigi IDS-süsteemid ja Wireshark märgistasid pordi 51820 automaatselt WireGuard VPN-tunneliks, tuvastas süvaanalüüs, et tegemist on tootjapoolse dünaamilise või kohandatud meedia-/telemeetriavoo sihtpordiga. Kuna seade on tehase püsivaraga ja ostetud jaemüügist, ei ole tegemist kolmanda osapoole pahatahtliku või peidetud VPN-tunneliga, vaid Ecovacsi pilvearhitektuuri spetsiifilise lahendusega reaajas kaardiandmete ja LiDAR-telemeetria edastamiseks.

B. Krüpteerimata liiklus (Port 80 TCP)

Tuvastati 90 krüpteerimata HTTP paketti. Päringute sihtkohtade filtreerimisel saadi järgmised tulemused:

- www.google.eu/generate_204
- conn-service-eu-04.allawnos.com/generate204
- www.baidu.com/

Tehniline selgitus: Need päringud viitavad seadme võrguühenduse kontrolli (Connectivity Check) loogikale. Seade testib enne krüpteeritud põhivoo püstitamist interneti olemasolu, pöördudes kolme sõlme poole:

Google (Euroopa standard), Allwunos (Ecovacci ametlik regioonipõhine domeen) ja Baidu (Hiina regiooni varukanal tõrkesiirdeks). See on tavapärane IoT seadmete käitumine ega viita andmelekketele.

6. Riskihinnang ja Kokkuvõte

Lõplik hinnang: Seade EI OLE otseses küberohus ega kompromiteeritud.

- **Konfidentsiaalsus (Puhas):** Roboti kriitilised andmed - ruumi kaardid, telemeetria, äpi ja seadme vaheline käsu vahetus - on täielikult krüpteeritud ega liigu sisevõrgus lahtise tekstina. Port 80 kaudu liikuvad Connectivity Check päringud ei sisalda kasutajaandmeid ega kujuta endast privaatsusrisi.
- **Terviklikkus (Turvaline):** Seadme võrgukäitumine oli 12-tunnise testi vältel stabiilne, reeglipärane ja prognoositav. Skaneerimise tuvastamise IDS-moodul ei tuvastanud ühtegi katset sisevõrgus *lateral movement* (külg-suunalise liikumise) või luuretegevuse algatamiseks teiste seadmete suunas. Robot käitub eeskujuliku võrgukliendina.

Soovitus edasiseks monitooringuks:

Kuna nutiseadmete püsivara uuendatakse tootja poolt dünaamiliselt taustal, on soovitatav teostada sarnane kontroll kord aastas. See võimaldab veenduda, et tootja pole tulevaste uuendustega muutnud reaalses kaardiandmete või videovoogu krüpteerimata kujul kättesaadavaks.

Raporti vormistas: Red Team Partner / Küberturvalisuse spetsialist

Projekt on ette valmistatud avalikustamiseks professionaalses portfoolios.